



BECODE CORP

COMPLIANCE AUDIT REPORT

AUDITOR TEAM :
ANDRÉ PENAS
JOHAN-EMMANUEL HATCHI
ZOLTÀN FRENYO

SECURE NETWORK DESIGN PROJECT

CYFUN 2025 FRAMEWORK ASSESSMENT

TLP:CLEAR · Educational simulation. BeCode Corp. and its network are fictitious, built for the BeCode bootcamp. Independent audit by the team above.

AUDIT OVERVIEW & COMPLIANCE CONTEXT

Hybrid assessment of BeCode Corp's "Secure Network Design" project against CyFun 2025 (Important level) framework, cross-referenced with NIS2, GDPR, and ISO/IEC 27001:2022.

Total Findings

18

Risk Findings

10 HIGH

Severity Level

7 CRITICAL

Security Posture

CRITICAL





CYFUN ASSURANCE LEVELS

1. SMALL / BASIC LEVEL

FOCUS: THIS IS THE ENTRY-LEVEL TIER DESIGNED FOR SMALL ORGANIZATIONS OR THOSE WITH A LOWER RISK PROFILE.

REQUIREMENTS: IT TYPICALLY INVOLVES A SUBSET OF ESSENTIAL SECURITY CONTROLS FOCUSING ON BASIC HYGIENE.

2. IMPORTANT LEVEL

FOCUS: THIS LEVEL IS INTENDED FOR MID-SIZED COMPANIES (SMES) OR ORGANIZATIONS THAT FALL UNDER ANNEX II OF THE BELGIAN NIS2 ACT.

REQUIREMENTS: IT FOLLOWS SIX KEY FUNCTIONS: GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, AND RECOVER.

3. ESSENTIAL / CRITICAL LEVEL

FOCUS: THIS IS THE HIGHEST TIER, RESERVED FOR LARGE ENTERPRISES OR "ESSENTIAL" ENTITIES LISTED IN ANNEX I OF THE NIS2 ACT.

REQUIREMENTS: IT DEMANDS THE MOST RIGOROUS IMPLEMENTATION OF CONTROLS, OFTEN REQUIRING HIGH MATURITY SCORES IN AUTOMATION AND PROACTIVE MONITORING.





CYFUN MATURITY LEVELS

Maturity Level	Maturity Value	Documentation Maturity Expectation of Documentation Maturity Level	Implementation Maturity Expectation of Implementation Maturity Level
Level 1 - Initial	1	No Process documentation or not formally approved by management.	Standard process does not exist.
Level 2 - Repeatable	2	Formally approved Process documentation exists but not reviewed in the previous 2 years.	Ad-hoc process exists and is done informally.
Level 3 - Defined	3	Formally approved Process documentation exists, and exceptions are documented and approved. Documented & approved exceptions < 5% of the time.	Formal process exists and is implemented. Evidence available for most activities. Less than 10% process exceptions.
Level 4 - Managed	4	Formally approved Process documentation exists, and exceptions are documented and approved. Documented & approved exceptions < 3% of the time.	Formal process exists and is implemented. Evidence available for all activities. Detailed metrics of the process are captured and reported. Minimal target for metrics has been established. Less than 5% of process exceptions.
Level 5 - Optimizing	5	Formally approved Process documentation exists, and exceptions are documented and approved. Documented & approved exceptions < 0,5% of the time.	Formal process exists and is implemented. Evidence available for all activities. Detailed metrics of the process are captured and reported. Minimal target for metrics has been established and continually improving. Less than 1% of process exceptions.



BECODE CORP

COMPLIANCE AUDIT REPORT

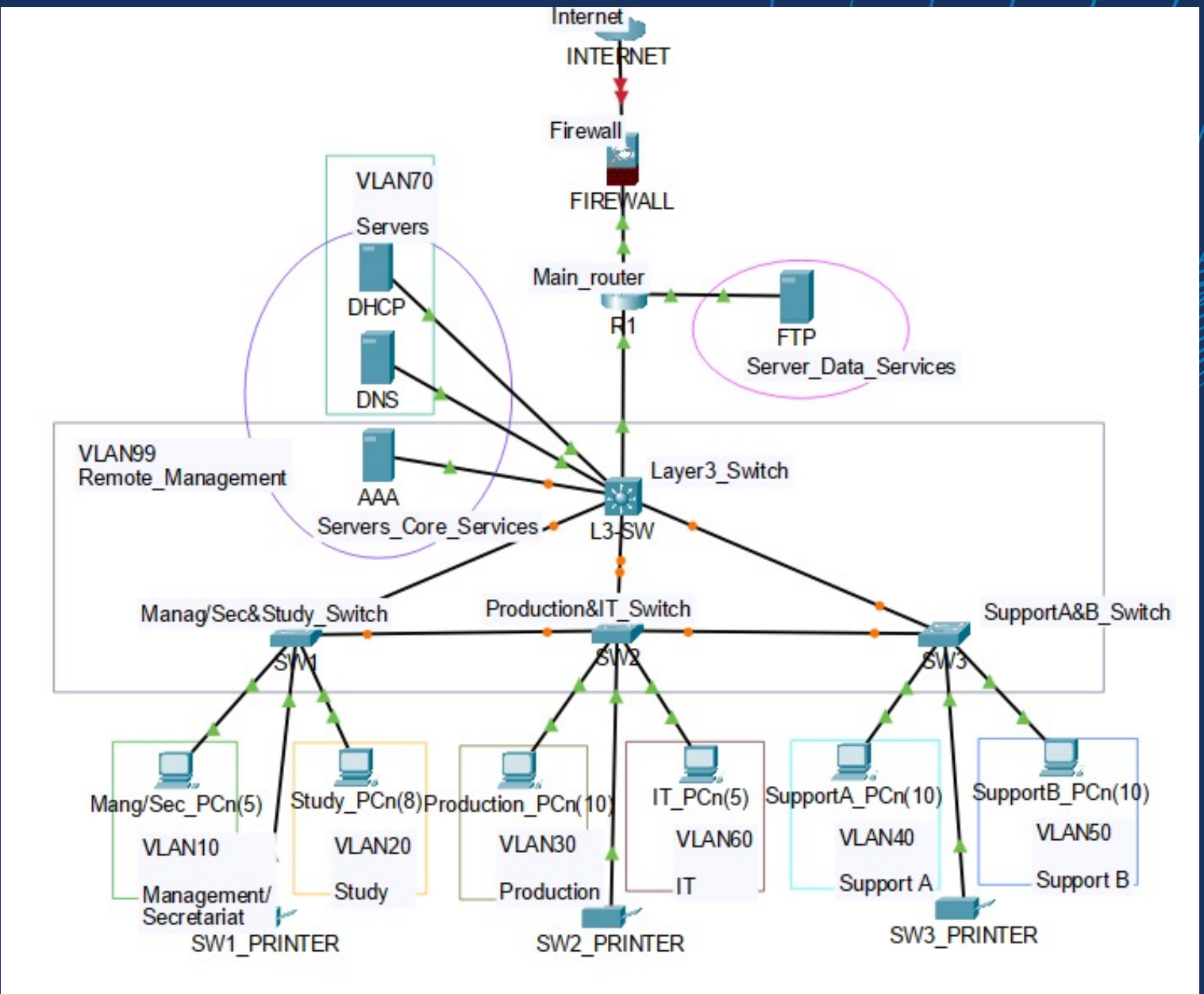
CLAIMS VS REALITY

Regular monitoring, logging, and auditing are implemented to detect anomalies, track user activity, and maintain compliance with security best practices. This comprehensive security approach ensures data integrity, confidentiality, and availability while supporting a reliable and scalable enterprise network infrastructure.





NETWORK TOPOLOGY





BECODE CORP

COMPLIANCE AUDIT REPORT

GOVERNANCE, POLICY & STRATEGIC GAPS

MISSING OVERSIGHT



GOVERN function unassessable due to complete absence of formal security policies, risk management documentation, and security governance framework.

PROCESS DEFECT



Systemic disconnect identified: documented security claims do not align with actual technical configurations, indicating fundamental governance breakdown.

IDENTITY & ASSETS



No onboarding/offboarding processes exist; orphan accounts and former users retain persistent access. Physical asset inventory present but no vulnerability or patch management program.





IDENTITY & ACCESS MANAGEMENT



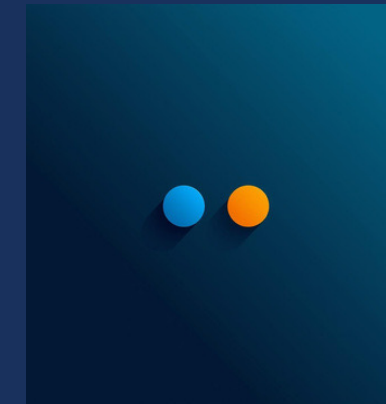
F-01/F-15

Trivial Credentials: Single weak admin password (cisco@123!) shared across all devices; technical users have identical username-password pairs.



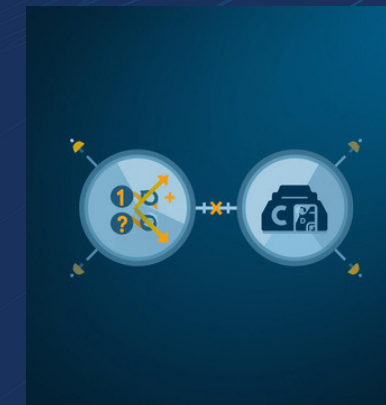
F-02

Absence of MFA: No multi-factor authentication for privileged access, directly violating NIS2 Article 21(2)(i) requirements.



F-03

Privilege Segregation: Binary access model where users have either full admin rights or no access; no read-only roles available.



F-14

AAA Protocol Mismatch: Clients configured for TACACS+ but server runs RADIUS, causing silent fallback to unmonitored local databases.



"BLIND & DEFENSELESS": DETECTION & RECOVERY



F-04 Logging & NTP

No centralized log server or NTP synchronization exists. Incident investigation and mandatory 24h NIS2 notifications are impossible.



F-05 No Detection

Complete absence of anti-malware, EDR, and Network IDS/IPS enables attacker lateral movement without any detection capability.



F-06 No Backups

No backup procedures exist for configurations or data, risking permanent loss from ransomware attacks or system failures.



F-07 Incident Response

No formal incident response plan or defined communication channels with CERT.be, leaving organization unprepared for breaches.



PERIMETER & CRYPTOGRAPHIC HARDENING



F-10 Firewall in Factory State

ASA 5506-X physically connected but no security zones configured, no filtering rules applied, Internet interface disabled.



F-09 Weak Cryptography

SSH management channels use deprecated 1024-bit RSA keys, failing NIS2's state-of-the-art security requirement.



F-16 Cleartext Transfers

FTP used without encryption on port 21; admin credentials found in plaintext within project documentation.



F-18 VTY Vulnerability

Lines 5-15 on switches allow cleartext Telnet access, lacking hardening commands present on lines 0-4.



BECODE CORP

COMPLIANCE AUDIT REPORT

NETWORK SEGMENTATION DEEP DIVE

F-17 ACL FAILURE



Inter-VLAN ACLs are defined in configuration but never applied to interfaces, resulting in a completely flat network topology with unrestricted lateral movement between departments.

F-11 TRUNK RISK



SW2 trunk ports accept all 4094 VLANs instead of explicitly allowed VLANs only, exposing the network to VLAN hopping attacks and unauthorized cross-segment access.

VLAN 1 ISSUES



Printers remain in default VLAN 1, which is also the active native VLAN on all trunk links. These gaps completely negate the claimed department-level segmentation.





BECODE CORP

COMPLIANCE AUDIT REPORT

REMEDIATION ROADMAP

IMMEDIATE (<24H)



Apply inter-VLAN ACLs to enforce segmentation, set ASA enable secret, and export all device configurations securely to protected storage within 24 hours.

SHORT-TERM (1-3 MO)



Deploy centralized Syslog server with NTP sync, implement versioned Git backups for all configurations, and resolve TACACS+/RADIUS protocol mismatch within 1-3 months.

STRATEGIC (6-18 MO)



Migrate to MFA-capable bastion host architecture, integrate EDR/IDS alerts into SIEM platform, and develop formal Business Continuity Plan (BCP) over 6-18 months.

CONCLUSION & FINANCIAL OUTLOOK

Compliance Status: Failed CyFun Important target in 5 of 6 functions (Protect, Detect, Respond, Recover, Govern). Path forward achievable in 6-12 months with dedicated cybersecurity ownership.

Functions Failed

5 OF 6

Budget Estimate

€30-80K

Compliance Path

6-12 MO

Priority Audit

SEC 10.1

